PROJECT 2

ROADMAP AT A GLANCE

PRIVACY-FIRST AGENTIC RAG

Document Intelligence + OCR + Hybrid Retrieval + Agents + Multimodal Scaling

START POINT
~1.5 GB input corpus (user estimate)

REUSE
Jina v3, Qdrant, Ollama, OCR

TARGET
Measured 10-150 GB readiness

D0-D15: ONE DELIVERY GATE AT A TIME

STATUS = code inspection only; no live deployment or benchmark verified.

D0	**Business workflow & baseline** Define users, evidence, NFRs	PLAN
D1	**Privacy, security & backups** Isolation + safe restore tested	NEW
D2	**Safe OCR & ingestion** Malicious ZIPs fail safely	PARTIAL
D3	**Parsing, metadata & chunks** Reindex/update without stale chunks	PARTIAL
D4	**Sparse / BM25 baseline** Exact-ID / lexical benchmark	NEW
D5	**Dense retrieval baseline** Jina v3 multilingual benchmark	EXISTS
D6	**Hybrid, rerank & grounding** Evidence-backed citation checks	PARTIAL
D7	**Structured information extraction** Typed fields + provenance	NEW
D8	**Evaluation & ablations** Frozen gold set + comparisons	PARTIAL
D9	**FastAPI & packaging** Stable typed APIs + smoke tests	NEW
D10	**Observability & reliability** Trace errors without leaking data	PARTIAL
D11	**Controlled agent workflows** Tool-using tasks + approval gates	NEW
D12	**Multimodal retrieval** Tables, figures, images with sources	NEW
D13	**Data-scale & load testing** 2 / 10 / 50 / 150 GB test reports	NEW
D14	**Secure deployment & guardrails** Authenticated, CI/CD, injection tests	NEW
D15	**Operations, rollback & ADRs** Restore drills + service runbook	NEW

Rule: Every stage must document the business need, alternatives, choice, evidence, trade-offs and an architecture decision record (ADR).

PROJECT 2 FOUNDATION & DATA QUALITY

SECURE BEFORE WE SCALE

The existing code is valuable, but the first upgrade must protect the data and make indexing recoverable.

D0 Business workflow & baseline

TO DEFINE

BUILD / FIX Identify tender users and real tasks: exact DTAD-ID lookup, tender comparison, evidence-based answers and report generation. Measure current counts and answer quality; record the 1.5 GB size as an estimate.

EXIT GATE Business objectives, document taxonomy, constraints, current-state architecture and baseline report approved.

D1 Privacy, security & backup

MISSING

BUILD / FIX Create source-data inventory, license/PII review, local-only network boundaries, secret handling and encrypted backups. Set retention and logging rules. Enforce least privilege and document-level authorization before retrieval.

EXIT GATE Snapshot can be restored; unauthorized reads blocked; external calls logged or denied; secrets not committed.

D2 Safe OCR and ingestion

PARTIAL

BUILD / FIX Harden io.py ZIP extraction against path traversal and archive bombs. Sandbox OCR/parsers, enforce file/type/size budgets, quarantine failures, and preserve OCR quality flags.

EXIT GATE Known malicious/corrupt ZIP and PDF fixtures are rejected without escaping the workspace.

D3 Parsing, metadata & chunking

PARTIAL

BUILD / FIX Define stable document IDs, page/section metadata, checksum/version tracking, Excel DTAD-ID normalization and chunker comparisons. Stop re-creating collections by default; remove stale chunks on edits/deletion.

EXIT GATE Incremental refresh produces no duplicates or orphaned chunks; source/page links survive reindexing.

HIGH-PRIORITY CODE FINDINGS

- index.py: fresh=True may delete the current collection during normal indexing.
- io.py: ZIP member paths are written before safe path/expansion validation.
- tender_bot_ui.py: disables TLS certificate verification process-wide.
- app_streamlit.py: untrusted chat text is rendered as HTML.
- qa.py: model-size validation runs on import; reranker loads per query and suppresses exceptions.

PROJECT 2 RETRIEVAL, GROUNDING, MEASUREMENT

PROVE ANSWER QUALITY

Build comparable baselines, then retain only changes that outperform alternatives on the same verified questions.

D4 Sparse / BM25 baseline

TO BUILD

BUILD / FIX Create lexical retrieval with exact-ID protection and German terminology tests. Compare BM25, full-text search and simple metadata lookup; avoid embedding-only answers for deterministic keys.

EXIT GATE Baseline Recall@K / MRR for exact IDs and terms recorded on a fixed, reviewed query set.

D5 Dense multilingual baseline

EXISTS - VERIFY

BUILD / FIX Reuse Qdrant + Jina v3 (1024-D), confirm query/document handling, dimensions, version pins and cross-language coverage. Tune top-K and chunk sizes without leaking evaluation labels.

EXIT GATE Reproducible German and English retrieval metrics, latency and embedding configuration recorded.

D6 Hybrid + reranking + grounding

PARTIAL

BUILD / FIX Implement real lexical+dense fusion (not only English/German dense fusion). Compare RRF/DBSF and optional BGE reranking. Verify citations against source files; handle abstentions.

EXIT GATE Ablation demonstrates chosen design on held-out queries; no fabricated source references.

D7 Structured information extraction

TO BUILD

BUILD / FIX Extract typed tender fields such as DTAD-ID, issuing body, dates, region, work package and requirements. Validate against Excel/source pages; record confidence and explicit evidence spans.

EXIT GATE Gold-labelled field extraction set passes agreed precision/recall and provenance checks.

D8 Evaluation, ablations & quality gates

PARTIAL

BUILD / FIX Create at least ~100 reviewed multilingual questions (initial target), including no-answer cases. Track Recall@K, nDCG/MRR, citation accuracy, faithfulness, P95 latency and regression tests.

EXIT GATE Frozen test splits and a documented model/retriever selection decision; thresholds set from baseline.

WHY THE ORIGINAL ROADMAP CHANGES HERE

Our use_hybrid=True flag currently routes through dense search; the existing RRF merges two dense-language queries, not BM25 + dense. We will validate sparse, dense, hybrid and reranked variants separately before choosing a winner.

PROJECT 2 APPLICATION, TRACES AND AGENTS

FROM SEARCH TO WORKFLOWS

Agents arrive only after retrieval, access control and evaluation are dependable.

D9 FastAPI & packaging

TO BUILD

BUILD / FIX Refactor ingestion/retrieval/answer services behind typed interfaces. Preserve Streamlit initially. Add /health, /search, /answer and /documents APIs with auth, request budgets and safe source download.

EXIT GATE Contract tests pass; UI and API return equivalent permitted results.

D10 Observability & reliability

PARTIAL

BUILD / FIX Consolidate custom loggers. Add request/trace IDs, retrieval/LLM timing, OCR failure rates, cost/resource counters and error budgets; redact prompts and document contents in telemetry.

EXIT GATE Any failed request is diagnosable from a private trace; no sensitive payload in standard logs.

D11 Controlled agent workflows

TO BUILD

BUILD / FIX Use one LangGraph orchestrator first. Tools: search_documents, lookup_metadata, read_section and create_report. Bound loops, steps and tool permissions; require approval for sensitive actions.

EXIT GATE Multi-step tender comparison tasks finish with evidence and bounded actions; injection tests cannot trigger unauthorized tools.

D12 Multimodal retrieval

TO BUILD

BUILD / FIX Add layout-aware tables, scanned-page images and figure extraction; evaluate vision/text retrieval against OCR-only. Later add audio transcripts and video keyframes only for a real use case.

EXIT GATE Table/image questions cite the correct original file, page and visual region with verified quality.

CONTROLLED AGENT EXAMPLE

User goal → Plan (bounded) → Search / SQL → Read evidence → Compare fields → Verify citations → Local report

Safeguards: read-only source tools by default; explicit approval for exports to external destinations; server-side permission checks; safe tool schemas; maximum steps, time and token budgets.

SCALE ON EVIDENCE

Dataset GB alone does not determine index size or required infrastructure. Benchmark actual chunks, vectors, concurrency and hardware.

D13 Load & data-scale testing

TO BUILD

BUILD / FIX Test 2 / 10 / 50 / 150 GB stages with authorized data and labelled synthetic fixtures. Track ingestion throughput, index size, storage growth, P95 query latency, failure recovery and concurrency.

EXIT GATE Published reproducible load reports and capacity plan; no unverified 150 GB performance claims.

D14 Secure deployment & guardrails

TO BUILD

BUILD / FIX Containerize services, lock dependencies, run CI, vulnerability checks and prompt-injection tests. Add authenticated roles, backup policies, secrets, TLS/network boundaries and manual release approvals.

EXIT GATE Deployment passes access-control and injection suites; can roll back without data loss.

D15 Production operations & ADRs

TO BUILD

BUILD / FIX Write SLOs, on-call/playbook, recovery tests, versioned configs, incident steps, feedback loop and audit trail. Adopt Kubernetes/Terraform only when operational evidence warrants it.

EXIT GATE Restore drills, rollback rehearsal, change history, cost tracking and service acceptance approved.

CAPACITY TEST MATRIX | PLANNED - NOT ACHIEVED

DATASET	ARCHITECTURE FOCUS	BENCHMARK QUESTION
~1.5-2 GB	local secure baseline	Can we reproduce and restore?
10 GB	incremental index + workers	Do changed files reprocess only?
50 GB	queues, parallel parsing, storage	Where are CPU / disk bottlenecks?
150 GB	sharding if justified, SLO tests	Does retrieval hold under load?

Capacity note: 150 GB of PDFs, scanned pages or video has very different retrieval and compute costs. Count chunks, vectors, metadata payload, replicas and multimodal artifacts separately.

WHAT TO CHANGE FIRST

A practical, non-destructive first iteration, plus the evidence rule from your reference diagram.

FIRST CODE CHANGESET: LEVEL D0-D1

1	**Backup**	Inventory current Qdrant collections, extract/raw data and config; produce a restore test.
2	**Prevent deletion**	Change index.py default to append and require a conscious --fresh flag for resets.
3	**Secure ingestion**	Fix io.py ZIP extraction paths, extraction limits and quarantining.
4	**Fix TLS + UI**	Remove SSL bypass in tender_bot_ui.py; eliminate unsafe raw HTML rendering.
5	**Record evidence**	Create README architecture map, ADR-0001, CI smoke tests and baseline query cases.

THE SIX-QUESTION DECISION RULE

01 BUSINESS	What workflow / user / loss are we improving?	**02 OPTIONS**	What simpler or alternative approach was tested?
03 CHOICE	Why this design over the alternatives?	**04 EVIDENCE**	What held-out metric or safety test supports it?
05 TRADE-OFF	What did we give up in cost, privacy or latency?	**06 REFERENCE**	Where are code, test report, benchmark and ADR?

REFERENCE DOCUMENTATION

- **Qdrant hybrid queries**
  qdrant.tech/documentation/hybrid-queries/
- **Qdrant self-hosted security**
  qdrant.tech/documentation/security/
- **Qdrant distributed deployment**
  qdrant.tech/documentation/distributed_deployment/
- **Docling supported formats**
  docling-project.github.io/docling/usage/supported_formats/
- **OWASP GenAI security Top 10**
  genai.owasp.org/initiatives/top-10-for-llm-and-genai/

Truthfulness note: All statuses and code findings are based on the uploaded files, not a running repository. Thresholds, 1.5 GB size and scale targets must be independently measured.